COMMON PITFALLS AND HOW TO AVOID THEM

Even well-meaning authorization policies can fall short in practice. Here are some common pitfalls the ACME identity team has encountered, along with strategies to avoid them:

Overly broad permits

Pitfall: Creating one policy that grants access to "all employees" instead of restricting it by role, project, or department.

Avoid it: Begin with *least privilege*. Limit conditions to the smallest group that needs access and specify scope explicitly.

Duplicating logic in multiple places

Pitfall: Embedding access checks across different applications, each with its own quirks.

Avoid it: Centralize your logic by externalizing it into policies as code. Reference the same policy set across services.

Mixing policy with data

Pitfall: Embedding data values such as department names or manager relationships directly into policy rules.

Avoid it: Keep attributes and relationships within authoritative systems (such as HR systems, identity stores, or graph databases). Policies should reference data, not define it.

Unclear naming

Pitfall: Using inconsistent names for actions or resources (for example, using `editDoc` in one place and `modify_document` in another).

Avoid it: Create and enforce naming conventions during reviews and with policy schemas. Clear policies are easier to read and maintain.